

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce
Session : Semester A 2011/12
Time allowed : Two hours

This paper has FOUR pages (including this cover page).

1. This paper consists of 6 questions.
 2. Answer ALL SIX questions.
 3. Total: 100 points
-

This is a closed-book examination.

Candidates are allowed to use the following materials/aids:

Approved Calculators

Materials/aids other than those stated above are not permitted. Candidates will be subject to disciplinary action if any unauthorized materials or aids are found on them.

**NOT TO BE
TAKEN AWAY**

**NOT TO BE TAKEN AWAY
BUT FORWARDED TO LIB**

Remark: Give concise reasons and show key steps in each problem. Keep your answers and reasons brief and right-to-the-point.

1. Symmetric Key Cryptography (15 points)

(a) (5 points)

Given ciphertext “**YMJ TYMJW XNIJ TK XNQJSHJ**”, try to decrypt it using Shift Cipher. Which key should try first? What is the plaintext?

(b) (10 points)

In a cipher called Vigenere cipher, the key is a stream of random numbers between 0 and 25. For example, if the key is 3 19 5 ..., then the first letter of plaintext is encrypted with a (cyclic) shift of 3 letters, the second with a shift of 19 letters, the third with a shift of 5 letters, and so on. Encrypt the following plaintext

sendmoremoney

with the key stream **9 0 1 7 23 15 21 14 11 11 2 8 9**

2. Operation Modes and Message Authentication (20 points)

(a) (6 points)

Let $E(K, M)$ be the AES encryption of message M under key K . Suppose that the operation mode is CBC. Let H be a hash function. Alice wants to send some secret information to Bob through the Internet. To ensure data confidentiality and message authentication, Alice is to choose one of the two approaches below.

Approach 1: Send $E(K, M \parallel H(M))$ to Bob

Approach 2: Send $E(K, M) \parallel H(E(K, M))$ to Bob

where the symbol ‘ $\parallel$ ’ represents binary string concatenation. After doing some security analysis, Alice finds that one approach is flawed.

(1) Identify the flawed one

(2) Describe an attack against the flawed approach

(b) (10 points)

Suppose you have a file encrypted using AES in CBC mode. Draw a decryption block diagram (show the decryption of three ciphertext blocks in the diagram). There are 100 blocks of ciphertext created. Suppose you want to decrypt the 50th ciphertext block. How many blocks of ciphertext do you actually need to decrypt? Which blocks of ciphertext are they?

(c) (4 points)

Suppose you have a file encrypted using AES in CBC mode. Suppose you want to modify the 50th ciphertext block. How many blocks of ciphertext do you need to re-encrypt? Which blocks are they?

3. Public Key Encryption (15 points)

(a) (5 points)

In an RSA cryptosystem, suppose that we are given a public key (n, e) where $e = 3$ and $n \equiv 2 \pmod{3}$. Find out the values of $p \bmod 3$ and $q \bmod 3$. Determine the value of the private key d .

(b) (10 points)

Let $p=2357$ and $g=2$. Suppose ElGamal encryption is used for encrypting a message M and the ciphertext $C = (A, B) = (1430, 697)$. Find M given that the private key $x = 1751$.

4. Authentication and Key Exchange (15 points)

(a) (5 points)

Illustrate a signature-based challenge-and-response protocol for one-way authentication. Assume that the challenger knows the public key of the responder and the responder has a private key for signature generation.

(b) (10 points)

Let p be a prime and g be the generator of the cyclic group Z_p^* . Describe the Diffie-Hellman key exchange and show how the man-in-the-middle attack works.

5. SSL, IPsec and Wireless Security (25 points)

(a) (8 points)

Consider the GSM security protocol below. Modify this protocol so that it achieves mutual authentication.

Protocol Steps:

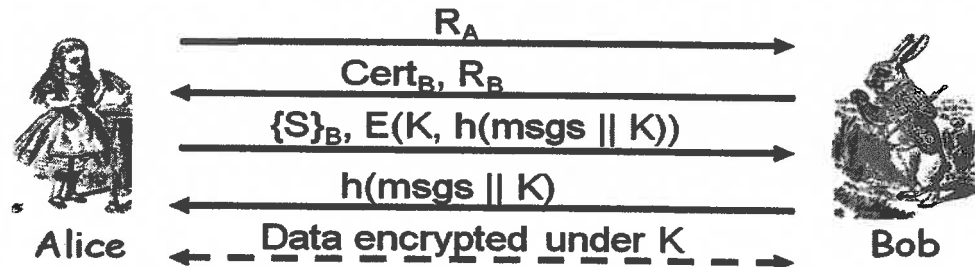
1. $M \rightarrow BS: IMSI$
2. $BS \rightarrow AuC: IMSI$
3. $BS \leftarrow AuC: RAND, XRES, Kc$
4. $M \leftarrow BS: RAND$
5. $M \rightarrow BS: SRES$

Notations: M: mobile; BS: base station; AuC: authentication centre

In your protocol description, specify the bit length of each new parameter introduced.

(b) (7 points)

Below is the simplified SSL protocol. Explain why the SSL protocol cannot allow the server (namely, Bob) to remain anonymous against eavesdroppers. Modify the protocol so that Bob can remain anonymous. Hint: The IPSec main mode public key protocols allow the users to remain anonymous.



(c) (5 points)

Suppose host A has an IP address 1.1.1.1 and host B has an IP address 2.2.2.2. If A sends an IPSec datagram to B using tunnel mode, what are the source and destination addresses of the inner as well as the outer IP headers?

(d) (5 points)

Name two properties of the IKE Phase 1, Signature Based (Main Mode) that are not supported by the IKE Phase 1, Signature Based (Aggressive Mode) and name one property that IKE Phase 1, Public Key Encryption Based (Aggressive Mode) supports but IKE Phase 1, Signature Based (Main Mode) does not.

6. Computer and Network Security (10 points)

(a) (5 points)

What is the common purpose of TCP ACK Scan and Firewall? Explain how the stateful packet filter defends against TCP ACK Scan attack.

(b) (5 points)

If the number of hops between an attacker's machine and a stateful packet filter is 3. What value of TTL should the attacker set for launching Firewall? Explain why Firewall does not work against Application Gateway.